

SIMATS ENGINEERING
ASSESSMENT TOOL II – INDUSTRY PROBLEM TASK

Course: Ethical Hacking	Code: ITA1408	CO: CO5
Duration:	Total Marks: 100	Reg No : 192411119 Name: P.Ranjithkumar

COURSE OUTCOME COVERED

***CO5:** Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Code of Conduct:

I P.Ranjithkumar-192411119 certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Prky

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning	Mark
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding; misinterprets problem context	
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts	
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution	
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools	
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis	
Professionalism	5%	Highly professional, well documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation	

1. A mid-sized financial organization operates a Windows domain network consisting of 150 interconnected systems. During a security incident investigation, it is observed that attackers have exploited NULL sessions, open RPC services, and misconfigured shared folders to gain unauthorized access. Initial analysis indicates that 45% of systems allow anonymous enumeration, and among those, 60% are susceptible to SMB-based lateral movement attacks. Furthermore, each compromised system can attempt to access 3 additional systems, with a success probability of 0.3 per attempt.

Question:

Analyze the extent of the attack by calculating the number of systems compromised during the initial stage of exploitation. Further, estimate the spread of the attack in the second stage due to lateral movement. Based on your analysis, evaluate whether the network is at risk of a large-scale compromise (greater than 70% of total systems), and justify which vulnerability (NULL sessions, RPC exposure, or weak shares) should be prioritized for immediate mitigation.

Introduction

The financial organization has a Windows domain network consisting of 150 interconnected systems. During a security incident, attackers exploited NULL sessions, open RPC services, and misconfigured shared folders to gain unauthorized access.

Given Information

Total number of systems = 150

Systems allowing anonymous enumeration = 45%

Systems susceptible to SMB-based lateral movement among those systems = 60%

Each compromised system attempts to access 3 additional systems

Success probability of each attempt = 0.3

Large-scale compromise threshold = Greater than 70% of the total systems

Initial Stage of Exploitation

- First, we calculate the number of systems that allow anonymous enumeration.
- Number of systems allowing anonymous enumeration:

$$150 \times 45 / 100 = 67.5$$

- Since the number of systems must be a whole number:

Approximately 68 systems

- Therefore, approximately 68 systems allow anonymous enumeration.
- Now, 60% of these systems are susceptible to SMB-based lateral movement.

$$68 \times 60 / 100 = 40.8$$

- Therefore: Approximately 41 systems
- Hence, approximately 41 systems are exposed to the SMB-based attack path during the initial stage.
- Initial Stage Result : Approximately 41 systems are considered compromised or exposed through the given initial attack path.

Second Stage - Lateral Movement

- Each compromised system can attempt to access 3 additional systems.
- The probability of successfully compromising each attempted system is 0.3.
- Expected successful compromises from one compromised system:

$$3 \times 0.3 = 0.9$$

- For approximately 41 systems : $41 \times 0.9 = 36.9$
- Thus, the expected number of additional systems compromised during the second stage is approximately 37 systems.

Total Estimated Number of Compromised Systems

Initial-stage systems = 41

Second-stage additional systems = 37

Total estimated compromised systems: $41 + 37 = 78$ systems

Therefore, approximately 78 systems could be compromised after the two stages.

Percentage of the Network Compromised

Total network systems = 150

Estimated compromised systems = 78

Percentage of compromised systems:

$$(78 / 150) \times 100 = 52\%$$

Therefore, approximately 52% of the network could be compromised after the two stages.

Evaluation of Large-Scale Compromise Risk

- The question defines a large-scale compromise as affecting more than 70% of the total network.
- First, calculate 70% of the total systems:

$$150 \times 70 / 100 = 105 \text{ systems}$$

- Therefore, more than 105 systems must be compromised to exceed the 70% threshold.
- Estimated compromised systems after two stages = 78 systems.
- Comparison: $78 < 105$
- In percentage terms : $52\% < 70\%$

Result:

The network does not reach a large-scale compromise of greater than 70% after the two stages considered in this question. However, the organization is still at significant risk because 78 out of 150 systems could potentially be compromised. If attackers continue lateral movement through additional stages, the number of affected systems could increase.

Analysis of the Identified Vulnerabilities

A. NULL Sessions

- NULL sessions can allow unauthenticated or anonymous access to certain Windows network services, depending on the system configuration.
- In this scenario, 45% of the systems allow anonymous enumeration. This gives attackers an opportunity to collect information about users, systems, shared resources, and other network details.
- Therefore, NULL-session exposure provides an important starting point for reconnaissance and further attacks.

B. Open RPC Services

- Remote Procedure Call (RPC) services are used by Windows systems for communication between different applications and systems.
- If RPC services are unnecessarily exposed or poorly secured, attackers may use them to gather information or exploit vulnerable services.

Vulnerability to Be Prioritized for Immediate Mitigation

- Among the three vulnerabilities, NULL sessions and anonymous enumeration should be prioritized for immediate mitigation.
- The main reason is that 45% of the organization's systems allow anonymous enumeration. This represents a large exposure across the network.
- Anonymous enumeration can provide attackers with useful information about users, shares, systems, and network resources. This information can then be used to support further attacks and lateral movement.

Recommended Security Measures

The organization should implement the following security measures:

1. Disable unnecessary NULL-session and anonymous access.
2. Restrict anonymous enumeration of users, shares, and network resources.
3. Secure SMB services and require proper authentication.
4. Review shared-folder permissions and follow the principle of least privilege.
5. Disable unnecessary RPC services.

Conclusion

The analysis shows that approximately 41 systems are exposed through the initial attack path created by anonymous enumeration and SMB-based lateral movement. Based on the given success probability, approximately 37 additional systems could be compromised during the second stage.

Therefore, the estimated total number of compromised systems after two stages is approximately 78 systems, which represents 52% of the 150-system network. Since 52% is below the 70% threshold, the network does not reach a large-scale compromise after the two stages considered.

Among the identified vulnerabilities, NULL sessions and anonymous enumeration should be given the highest immediate priority because 45% of the systems are exposed to anonymous enumeration. Securing NULL sessions, followed by hardening RPC services and correcting shared-folder permissions, will help reduce the attack surface and limit lateral movement across the Windows domain network.

2. An enterprise network consists of 120 systems, out of which 70 systems expose RPC services to the internal network. A vulnerability scan reveals that 40% of these systems are susceptible to known exploits, and the probability of successful exploitation for each vulnerable system is 0.5. However, each exploitation attempt carries a detection probability of 0.25 due to intrusion detection systems deployed within the network.

Question:

Determine the expected number of systems that can be successfully compromised by an attacker. Additionally, compute the expected number of detection alerts generated during the exploitation process. Based on your results, critically evaluate whether an attacker aiming to remain stealthy would proceed with exploitation or adopt alternative attack strategies, providing justification for your reasoning.

Given Information

- Total number of systems = 120
- Systems exposing RPC services = 70
- Percentage of RPC-exposed systems susceptible to known exploits = 40%
- Probability of successful exploitation for each vulnerable system = 0.5
- Detection probability for each exploitation attempt = 0.25

1. Calculation of Vulnerable Systems

The first step is to determine how many of the 70 systems exposing RPC services are susceptible to the known exploits.

$$70 \times 40 / 100 = 28 \text{ systems}$$

Therefore, 28 systems are susceptible to the known exploits. These systems form the set on which exploitation attempts are considered.

2. Expected Number of Successfully Compromised Systems

- The probability of successful exploitation for each vulnerable system is 0.5. Therefore, the expected number of successful compromises is calculated by multiplying the number of vulnerable systems by the success probability.

$$28 \times 0.5 = 14 \text{ systems}$$

- Therefore, the expected number of successfully compromised systems is 14.
- This is an expected value rather than a guarantee. In an actual incident, the number may be different because of system configuration, patch status, exploit availability, credentials, and defensive controls.

3. Expected Number of Detection Alerts

- Each exploitation attempt has a detection probability of 0.25. Assuming one relevant exploitation attempt for each of the 28 vulnerable systems, the expected number of detection alerts is:

$$28 \times 0.25 = 7 \text{ alerts}$$

- Therefore, approximately 7 detection alerts are expected during the exploitation process.
- The result shows that the intrusion detection system has a meaningful opportunity to identify the attack activity. However, detection does not automatically mean that exploitation has been stopped; the alerts must be investigated and followed by an appropriate response.

4. Evaluation from a Stealth Perspective

- a. An attacker who wants to remain stealthy must consider both the chance of successful exploitation and the chance of being detected. Direct exploitation of all vulnerable RPC systems can create repeated security events and increase the likelihood of attracting attention.
 - There are 28 systems susceptible to the known exploits.
 - The expected number of successful compromises is 14 systems.
 - The expected number of detection alerts is 7.
 - Repeated exploitation creates multiple opportunities for the intrusion detection system to identify suspicious activity.
- b. Every exploitation attempt has a detection probability of 0.25, a stealth-focused attacker would have a reason to avoid repeated noisy exploitation.
- c. From a defensive viewpoint, this also means that the organization should expect attackers to look for other paths if direct RPC exploitation becomes highly visible.
- d. Therefore, the security team should not rely only on the detection system. RPC exposure must also be reduced so that vulnerable services are not unnecessarily available to attackers.

5. Impact on the Network

- The expected 14 compromised systems represent a portion of the organization's 120 systems.
- Percentage of systems expected to be compromised:

$$(14 / 120) \times 100 = \mathbf{11.67\%}$$

- Therefore, the expected compromise is approximately 11.67% of the total network during this exploitation stage.
- Although this is below a majority of the network, it is still a serious concern because compromised systems can potentially be used as a starting point for further attacks. Therefore, early detection and containment are important to prevent the incident from becoming larger.

6. Security Evaluation and Mitigation

The calculation demonstrates that RPC exposure represents a meaningful security weakness. Although 70 systems expose RPC services, 28 of those systems are susceptible to known exploits. This provides a potential attack surface that should be reduced.

- Disable unnecessary RPC services.
- Restrict required RPC services to trusted systems and networks.
- Apply security patches to systems susceptible to known exploits.
- Use firewall rules and network segmentation to limit RPC communication.
- Correlate intrusion detection alerts with endpoint and authentication logs.

Conclusion

The analysis identifies 28 vulnerable systems. With a successful exploitation probability of 0.5, the expected number of successfully compromised systems is 14. With a detection probability of 0.25 per attempt, approximately 7 alerts are expected. Therefore, an attacker attempting to remain stealthy would face a meaningful detection risk from repeated direct exploitation. The organization should reduce RPC exposure, patch vulnerable systems, and maintain effective monitoring and incident response.

3. A cloud-hosted Linux server is running multiple services exposed to the internet. Security analysis identifies four critical services, with independent probabilities of vulnerability being 0.3, 0.2, 0.25, and 0.15, respectively. It is also observed that the system has weak file permissions, which can be exploited with a probability of 0.5 once initial access is gained.

Question:

Evaluate the probability that at least one service is vulnerable and can be exploited by an attacker. Further, compute the overall probability of a full system compromise, considering privilege escalation through weak permissions. Based on your findings, analyze whether strengthening file permissions alone would significantly reduce the overall risk, and justify your conclusion.

Given Information

- Vulnerability probability of Service 1 = 0.30
- Vulnerability probability of Service 2 = 0.20
- Vulnerability probability of Service 3 = 0.25
- Vulnerability probability of Service 4 = 0.15
- Probability of privilege escalation through weak file permissions = 0.50

1. Probability that No Service Is Vulnerable

The four service vulnerabilities are independent. Therefore, the probability that none of the four services is vulnerable is calculated by multiplying their individual non-vulnerability probabilities.

$$\begin{aligned} &= (1 - 0.30) \times (1 - 0.20) \times (1 - 0.25) \times (1 - 0.15) \\ &= 0.70 \times 0.80 \times 0.75 \times 0.85 \\ &= 0.357 \end{aligned}$$

Therefore, the probability that none of the services is vulnerable is 0.357, or 35.7%.

2. Probability that at Least One Service Is Vulnerable

The probability that at least one service is vulnerable is the complement of the probability that none of the services is vulnerable.

$$\begin{aligned} 1 - 0.357 &= 0.643 \\ 0.643 \times 100 &= 64.3\% \end{aligned}$$

- Therefore, there is a 64.3% probability that at least one of the four internet-facing services is vulnerable.
- This represents a significant exposure because the server is directly reachable from the internet. A single vulnerable service can provide an initial access path even when the other services are secure.

3. Overall Probability of Full System Compromise

Full compromise requires two stages: first, at least one exposed service must be vulnerable and provide initial access; second, the weak file permissions must allow successful privilege escalation.

Probability of full compromise = 0.643×0.5

$$= 0.3215$$

$$0.3215 \times 100 = 32.15\%$$

Therefore, the overall probability of a full system compromise is approximately 32.15%.

4. Effect of Strengthening File Permissions Alone

- a. Strengthening file permissions is an important mitigation because it directly reduces the probability that an attacker with initial access can escalate privileges.
- b. In the given model, the privilege-escalation probability is 0.5, so reducing this weakness lowers the probability of progressing from initial access to full compromise.
 - It reduces the second stage of the attack path.
 - It limits the attacker's ability to obtain higher privileges after initial access.
 - It reduces the probability of full system compromise.
 - It does not remove vulnerabilities in the four internet-facing services.
- c. The important limitation is that file-permission hardening alone does not eliminate the initial access risk.
- d. The probability of at least one exposed service being vulnerable remains 64.3% under the assumptions in the question. Therefore, the organization must also patch and harden internet-facing services.

5. Impact of Weak File Permissions

Weak file permissions increase the risk after an attacker obtains initial access.

- The probability of privilege escalation is 0.5.
- This means there is a 50% probability of successful privilege escalation once initial access is gained, according to the given scenario.
- Successful privilege escalation can allow an attacker to obtain higher privileges.
- Higher privileges can provide greater control over files, services, configurations, and system resources.
- Therefore, weak file permissions can significantly increase the impact of an initial compromise.

For this reason, file and directory permissions should follow the principle of least privilege, where users and applications receive only the permissions necessary to perform their tasks.

6. Recommended Security Measures

- Patch and update all internet-facing Linux services.
- Disable services that are not required for business operations.
- Restrict management services using firewalls and trusted source networks.
- Apply least-privilege permissions to files and directories.
- Monitor authentication and privilege-escalation events.
- Use network segmentation to limit the impact of a compromised server.

Conclusion

The probability that at least one of the four exposed services is vulnerable is 64.3%. When the 0.5 probability of privilege escalation through weak file permissions is included, the estimated probability of full system compromise is 32.15%. Strengthening file permissions can significantly reduce the chance of full compromise, but it cannot replace protection of internet-facing services. Both service hardening and permission hardening are necessary.

4. An organization uses Network File System (NFS) to share resources across three internal subnets. Due to improper configuration, unauthorized access probabilities from these subnets are estimated as 0.4, 0.3, and 0.2, respectively. Once access to the NFS share is obtained, the probability of privilege escalation to root access is 0.7.

Question:

Calculate the probability that at least one subnet successfully gains unauthorized access to the NFS share. Subsequently, determine the overall probability of a complete system compromise. Based on your analysis, evaluate the effectiveness of restricting NFS access to a single subnet as a mitigation strategy, and justify your recommendation.

Given Information

- Subnet 1 unauthorized-access probability = 0.4
- Subnet 2 unauthorized-access probability = 0.3
- Subnet 3 unauthorized-access probability = 0.2
- Probability of privilege escalation to root access = 0.7

1. Probability that At Least One Subnet Gains Unauthorized Access

- a. The probability that at least one subnet gains unauthorized access is calculated using the complement rule. First, we calculate the probability that none of the three subnets gains unauthorized access.

$$\begin{aligned} & (1 - 0.4) \times (1 - 0.3) \times (1 - 0.2) \\ &= 0.6 \times 0.7 \times 0.8 \\ &= 0.336 \end{aligned}$$

- b. Therefore, the probability that none of the three subnets gains unauthorized access is 0.336, or 33.6%.

- c. The probability that at least one subnet gains unauthorized access is:

$$\begin{aligned} P(\text{At least one unauthorized access}) &= 1 - P(\text{None}) \\ &= 1 - 0.336 \\ &= 0.664 \\ &= 66.4\% \end{aligned}$$

2. Overall Probability of Complete System Compromise

Complete system compromise requires two stages. First, at least one subnet must successfully gain unauthorized access to the NFS share. Second, after obtaining access, privilege escalation to root must be successful.

Probability of unauthorized access = 0.664

Probability of privilege escalation to root = 0.7

$P(\text{Complete compromise}) = 0.664 \times 0.7$

$$= 0.4648$$

$$= 46.48\%$$

Therefore, the overall probability of complete system compromise is approximately 46.48%.

This result shows that the NFS configuration represents a considerable security risk. The probability of unauthorized access is already 66.4%, and the additional possibility of privilege escalation increases the potential impact after access has been obtained.

3. Analysis of the Security Risk

- The probability that none of the subnets gains unauthorized access is 33.6%.
 - The probability that at least one subnet gains unauthorized access is 66.4%.
 - The probability of privilege escalation to root after access is obtained is 70%.
 - The overall probability of complete system compromise is 46.48%.
- a. The calculated values indicate that both the NFS access configuration and privilege escalation contribute to the overall security risk.
 - b. Since the NFS share can be reached from three internal subnets, improper access restrictions may provide multiple opportunities for unauthorized access.

4. Effectiveness of Restricting NFS Access to a Single Subnet

- a. Restricting NFS access to a single subnet can reduce the attack surface because the NFS share would no longer be accessible through all three subnet paths.
- b. This mitigation is particularly effective when access is limited to the subnet that genuinely requires the NFS resource.
- c. If the organization restricts NFS access to Subnet 3, which has the lowest stated unauthorized-access probability of 0.2, the estimated probability of complete compromise becomes:

$$P(\text{Complete compromise}) = 0.2 \times 0.7$$

$$= 0.14$$

$$= 14\%$$

Reduction in estimated risk : $46.48\% - 14\% = 32.48$ percentage points

5. Justification of the Recommendation

- NFS access should be provided only to systems and users that genuinely require the shared resource.
- Limiting access to one authorized subnet reduces the number of possible access paths.
- Firewall rules can be used to allow NFS traffic only from approved systems.
- Least-privilege permissions can reduce the impact of unauthorized access.
- NFS export configurations should be reviewed regularly to remove unnecessary access.

Restricting NFS access should therefore be treated as an important preventive control rather than the only security measure. It should be combined with proper authentication, least privilege, firewall restrictions, monitoring, and regular configuration reviews.

6. Overall Evaluation

The analysis shows that the organization faces a significant risk from the current NFS configuration. With three subnets having unauthorized-access probabilities of 0.4, 0.3, and 0.2, the probability that at least one subnet gains unauthorized access is 66.4%. When the 0.7 probability of privilege escalation is included, the overall probability of complete system compromise is 46.48%.

Conclusion

The probability that at least one subnet successfully gains unauthorized access to the NFS share is 66.4%. The overall probability of complete system compromise, after considering the 0.7 probability of privilege escalation to root, is 46.48%.

Restricting NFS access to a single appropriately selected subnet can reduce the estimated complete-compromise probability to 14% when the subnet with probability 0.2 is selected. Therefore, restricting NFS access is an effective mitigation strategy because it reduces the number of possible access paths. The organization should combine this measure with least-privilege permissions, strong access control, firewall restrictions, monitoring, and regular NFS configuration reviews.

5. An e-commerce platform maintains a database containing 50,000 user records, of which 30% are classified as sensitive. A successful SQL injection attack allows data extraction at a rate of 500 records per second. However, the application firewall detects and blocks the attack after 40 seconds.

Question:

Compute the total number of records that can be extracted before the attack is blocked. Determine the percentage of total data compromised, and estimate the number of sensitive records exposed. Based on your analysis, evaluate the severity of the breach and justify whether the existing detection mechanism is sufficient to protect critical data.

Given Information

- Total number of user records = 50,000
- Percentage of records classified as sensitive = 30%
- Data extraction rate during SQL injection = 500 records per second
- Application firewall blocks the attack after 40 seconds

1. Total Number of Records Extracted

The SQL injection attack extracts data at a rate of 500 records per second. The application firewall blocks the attack after 40 seconds.

Total records extracted = Extraction rate $\times$ Attack duration

$$= 500 \times 40$$

$$= 20,000 \text{ records}$$

Therefore, the attacker can extract a total of 20,000 records before the application firewall blocks the attack.

2. Percentage of Total Data Compromised

The database contains 50,000 records, while 20,000 records can be extracted before the attack is blocked.

Percentage of data compromised = (Records extracted / Total records) $\times$ 100

$$= (20,000 / 50,000) \times 100$$

$$= 40\%$$

Therefore, approximately 40% of the total user records can be compromised before the firewall blocks the attack. This is a substantial proportion of the database, showing that a high extraction rate can allow significant data loss within a short period.

3. Number of Sensitive Records Exposed

- Sensitive records represent 30% of the total database.

Total sensitive records = $50,000 \times 30 / 100$

= 15,000 sensitive records

- Assuming the extracted records have the same 30% proportion of sensitive data as the overall database:

Sensitive records exposed = $20,000 \times 30 / 100$

= 6,000 sensitive records

- Therefore, approximately 6,000 sensitive records may be exposed. This is an estimate because the actual records selected by an attack may not have exactly the same proportion of sensitive data as the complete database.

4. Analysis of the Breach Severity

- The attacker can extract 20,000 records in only 40 seconds.
- The extracted records represent 40% of the complete database.
- Approximately 6,000 of the extracted records may be sensitive.
- A large amount of information can therefore be exposed before the firewall responds.
- The incident demonstrates that detection based only on response time may not prevent significant data loss.

5. Evaluation of the Existing Detection Mechanism

The application firewall provides an important security layer because it detects and blocks the SQL injection attack after 40 seconds. However, the calculations show that the current response time is not sufficient by itself to protect critical data.

- The firewall stops the attack, but 20,000 records are already extracted.
- 40% of the entire database can be compromised during the 40-second window.
- Approximately 6,000 sensitive records may be exposed during this period.
- Therefore, blocking the attack after detection does not prevent significant data loss.

6. Recommended Security Measures

- Use parameterized queries or prepared statements to prevent SQL injection.
- Validate and sanitize user input before it reaches database queries.
- Apply least-privilege permissions to database accounts.
- Configure the application firewall to detect and block suspicious activity quickly.
- Implement database activity monitoring for unusual data extraction.
- Use rate limiting to reduce excessive data retrieval.
- Encrypt sensitive data during storage and transmission.
- Maintain detailed security logs and review them regularly.
- Conduct regular vulnerability assessments and security testing.
- Keep the application, database, and security systems updated.

7. Overall Security Assessment

The existing firewall is useful as a detection and containment mechanism, but it should not be treated as the only protection for the database. The calculation shows that an attacker can extract 20,000 records before the attack is blocked. Since this represents 40% of all records and may include approximately 6,000 sensitive records, the potential impact is high.

A stronger security architecture should prevent SQL injection at the application layer and limit the privileges available to the database account. The firewall should act as an additional defensive layer rather than the primary mechanism for protecting critical data.

Conclusion

The SQL injection attack can extract 20,000 records before the application firewall blocks it. This represents 40% of the total 50,000 user records. Since 30% of the database is sensitive, approximately 6,000 sensitive records may be exposed.

Therefore, the breach should be classified as serious because a large portion of the database, including a significant number of sensitive records, can be accessed within only 40 seconds. The existing detection mechanism is helpful because it eventually blocks the attack, but it is not sufficient by itself to protect critical data. The organization should combine firewall protection with parameterized queries, input validation, least-privilege database access, monitoring, rate limiting, encryption, and regular security testing.

